des vulnérabilités connues et examiner les fonctionnalités douteuses qui pourraient permettre des actions non-intentionnelles.

- 4 - Exploitation : Une fois que nous avons trouvé des vulnérabilités potentielles, nous préparons notre code d'exploitation, nos outils et notre environnement et nous testons le server web pour ces vulnérabilités potentielles
- 5 - Post-Exploitation : Une fois que nous avons exploité avec succès la cible nous passons à la collecte d'informations et examinons le server Web de l'intérieur. Si nous trouvons des informations sensibles à ce stade nous essayons d'élever nos privilège (selon le system et les configurations
- 6 - Mouvement Latéral : Si d'autres serveurs et hotes du reseau interne dans le perimetre nous essayons de nous déplacer à travers le réseau et d'accéder à d'autres hotes et serveurs en utilisant les informations que nous avons recueillies.
- 7 - Preuves de Concept : Nous créons une preuve de concept (POC) qui prouvent que les vulnérabilités existent et nous automatisons potentiellement même les étapes individuelles qui prouvent ces vulnérabilités
- 8 - Post-Engagement : Enfin la documentation est finalisé et présenté à notre client sous forme de rapport formel. Ensuite nous pouvons organiser une reunion de présentation du rapport pour clarifier tout ce qui concerne nos tests et résultat et fournir tout le soutient nécessaire au personnel chargé de remédier à nos découvertes.

Le Pré-Engagement :

Contrat, points de contrôle et description :

- NDA : ou accord de non-divulgation est un contrat de fidélité entre le client et le prestataire concernant toute les informations écrites ou verbales relatives à une commande / un projet. Le prestataire s'engage à traiter comme strictement confidentielles toute les données confidentielles portées à sa connaissance même après l'achevement du contrat. Les exceptions à la confidentialité, la traçabilités des droits et obligations et les pénalités contractuelles doivent être stipulés dans l'accord. Le NDA doit être signé avant la reunion de lancement et au plus tard pendant.

- Les objectifs : ce sont des jalons qui doivent être atteints au cours de la commande/projet. On commence par les objectifs globaux puis de plus en plus petits.

- Le perimètre : Les différents composant a tester sont discuter et définis, il s'agit de noms de domaine de plages d'adresse IP, Hotes individuelles, comptes spécifiques, systèmes de sécurité etc... Nos clients peuvent s'attendre à ce que nous découvrions nous même l'un ou l'autre point. La base juridique pour tester les différents composants à ici la plus haute priorité.

- Type de test d'intrusion : Nous présentons au client les différentes options ainsi que leurs avantage et inconvenient. Comme nous connaissons les objectifs et le périmetre nous pouvons faire des recommendation. Le type utilisé sera le choix du client.

- Methodologie : Exemples OSSTMM, OWASP, analyse non authentifiée et manuelle des composants réseaux internes/externes, evaluation des vulnerabilités des composant réseaux et application web.

- Lieu de Test d'Intrusion : Externe ou interne (via VPN sécurisé)

- Estimation du Temps : Dates de début et de la fin du test d'Intrusion. Cela nous aide à planifier le pentest. Il est également nécessaire de déterminer la durée de chaque étapes. Les heures peuvent lorsque se situer en dehors des heures de travail habituelles.